P6 Jarkom Lanjutan

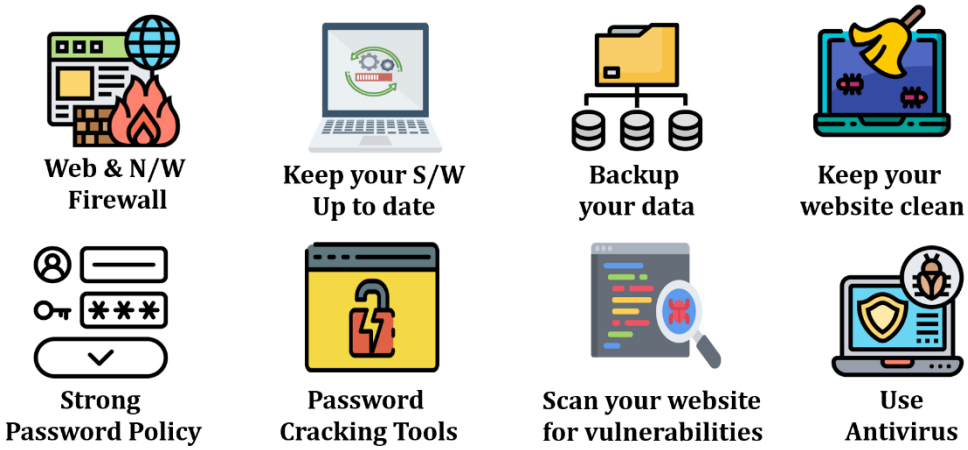
Web Security dan Webmail

NAMA	:	Ihsanta Zaki Sanjaya
KELAS	:	3 Teknik Komputer B
NRP	:	3223600058
DOSEN	:	Ir Sigit Wasista M.Kom
MATA KULIAH	:	Jaringan Komputer Lanjutan
TANGGAL	:	Senin, 29 September 2025

D4 TEKNIK KOMPUTER
POLITEKNIK ELEKTRONIKA NEGERI SURABAYA
2025

Pertanyaan Tentang Keamanan Web (Web Security)

1. Apa yang dimaksud dengan keamanan web (web security), dan mengapa itu penting?



Keamanan web merupakan salah satu cara dalam mengamankan dan melindungi website. Dapat berupa rangkaian tindakan, teknologi, dan kebijakan yang dirancang untuk melindungi aplikasi web, server tempat aplikasi dijalankan, data yang disimpan atau ditransmisikan, serta pengguna yang berinteraksi dengan layanan tersebut. Keamanan web tidak hanya bicara tentang menutup celah teknis seperti bug atau konfigurasi yang salah, tetapi juga mencakup desain arsitektur (pemisahan layanan, enkripsi end-to-end), proses pengembangan (secure SDLC/Software Development Life Cycle), serta aspek organisasi seperti tata kelola, kebijakan akses, dan kesiapan insiden. Tujuan utamanya adalah menjaga tiga pilar keamanan, yaitu kerahasiaan (confidentiality) agar data sensitif tidak bocor, integritas (integrity) agar data dan fungsi tidak diubah oleh pihak tidak berwenang, dan ketersediaan (availability) agar layanan tetap dapat diakses oleh pengguna yang sah. Di lapangan, tindakan keamanan web bisa berkisar dari penerapan HTTPS dan firewall sampai audit konfigurasi, enkripsi database, dan pelatihan kesadaran keamanan untuk tim.

Jenis-jenis keamanan web relatif beragam karena area ancaman dan titik lemah juga beragam. Pada level aplikasi ada praktik seperti validasi input, output encoding, sanitasi, dan penerapan prinsip least privilege untuk mencegah XSS, SQL Injection, atau logic flaws. Pada level transport ada TLS/HTTPS untuk melindungi data dalam perjalanan, pada level infrastruktur ada firewall jaringan, segmentasi jaringan, dan pengelolaan patch untuk mencegah eskalasi akses, pada level identitas ada manajemen akses dan identitas (IAM), kebijakan password, dan penggunaan MFA untuk mengurangi risiko compromised accounts. Selain itu muncul kategori khusus seperti Web Application Firewall (WAF) yang memfilter lalu lintas HTTP/HTTPS, sistem deteksi/ pencegahan intrusi (IDS/IPS), proteksi DDoS, serta kontrol pada supply-chain. Misalnya scanning dependency dan kontrol package manager, yang penting mengingat banyak aplikasi modern bergantung pada pustaka pihak ketiga. Setiap jenis ini saling melengkapi, mengandalkan satu teknik saja hampir selalu tidak cukup.

Kerentanan web berpotensi menimbulkan dampak besar, kebocoran data pelanggan, pencurian kredensial, penipuan finansial, defacement situs, atau gangguan layanan yang menyebabkan hilangnya pendapatan dan kepercayaan pelanggan. Dampak finansialnya bisa signifikan, biaya penyelidikan, denda kepatuhan, kompensasi pengguna, hingga biaya pemulihan teknis, dan dampak reputasional seringkali lebih lama terasa daripada perbaikan teknisnya. Di banyak industri ada juga kewajiban regulatori (perlindungan data pribadi, standar kartu pembayaran) yang mensyaratkan bukti kontrol keamanan tertentu; kegagalan memenuhi persyaratan tersebut bisa berujung sanksi hukum. Selain itu, keamanan web mendukung kontinuitas bisnis dan keberlangsungan layanan: organisasi yang dapat menunjukkan postur keamanan yang baik lebih mampu menjaga operasi saat terjadi insiden dan lebih cepat pulih.

Implementasi keamanan web yang efektif dalam praktik kerja maupun industry mengikuti prinsip defense-in-depth dan terintegrasi ke dalam proses bisnis sehari-hari. Best practice yang umum diterapkan meliputi melakukan penilaian risiko dan threat modelling sebelum pembangunan fitur, mengintegrasikan security testing otomatis (SAST, DAST, dependency scanning) ke pipeline CI/CD, menerapkan prinsip least privilege pada akun dan layanan, menggunakan parameterized queries/ORM untuk mencegah injeksi, serta memastikan semua komunikasi terenkripsi dengan TLS yang dikonfigurasi aman. Di sisi operasi, patch management rutin, pemantauan dan logging terpusat (SIEM), alerting yang actionable, dan runbook untuk insiden menjadi elemen wajib. Banyak organisasi juga menggunakan layanan terkelola (CDN + WAF, managed IDS, cloud IAM) untuk mengurangi kompleksitas operasional, sambil tetap melakukan pentest berkala dan red-team exercise untuk menguji kesiapan. Selain teknologi, faktor manusia penting, program pelatihan secure coding untuk developer, security champions dalam tim produk, dan kebijakan respons insiden yang terlatih membuat kontrol teknis menjadi lebih efektif.

2. Jelaskan bagaimana serangan Cross-Site Scripting (XSS) dapat mempengaruhi keamanan sebuah website.

   Serangan Cross-Site Scripting (XSS) merupakan jenis serangan injeksi di mana penyerang menyelipkan kode berbahaya, biasanya JavaScript tetapi bisa juga HTML atau bentuk lain yang bisa dieksekusi oleh browser, ke dalam halaman web yang tampak sah. Serangan ini terjadi ketika aplikasi web memasukkan data dari sumber yang tidak tepercaya (parameter URL, form, atau isi yang disimpan di database) ke dalam output HTML tanpa memvalidasi atau melakukan encoding terlebih dahulu. Karena browser menganggap konten halaman berasal dari situs yang dipercaya, skrip jahat itu dijalankan oleh browser korban seolah-olah berasal dari situs tersebut. Secara umum XSS dibagi beberapa tipe, reflected XSS, yaitu payload dikirim lewat URL atau form lalu langsung “dipantulkan” kembali oleh server dalam respons (sering digunakan lewat link jahat dalam e-mail atau phishing), stored XSS, payload disimpan permanen di server (di komentar, profil, guestbook) sehingga akan mempengaruhi setiap

pengunjung yang melihat konten tersebut, dan DOM-based XSS, yang terjadi sepenuhnya di sisi klien ketika skrip halaman memanipulasi DOM menggunakan input berbahaya tanpa sanitasi. Ada juga varian seperti blind XSS, di mana payload tersimpan dan baru dieksekusi ketika seorang admin atau backend user membuka data tersebut, serangan ini sulit dideteksi karena efeknya tidak langsung tampak bagi pelaku.

Dampak XSS dapat berkisar dari gangguan kecil sampai kompromi akun total, skrip jahat bisa mencuri cookie atau token sesi, mengirimkan data formulir ke server penyerang, melakukan redirect ke halaman phishing, mengubah tampilan konten, atau men-trigger download malware. Kasus serius bahkan bisa mempengaruhi reputasi perusahaan (mengubah press release), atau berbahaya pada situs medis jika informasi dosis dimanipulasi. Untuk melindungi aplikasi perlu pendekatan berlapis, cari dan perbaiki semua titik di mana input HTTP bisa masuk ke output HTML (code review), terapkan output encoding/escaping sesuai konteks, gunakan validasi input, setel cookie sensitif dengan HttpOnly/Secure, nonaktifkan HTTP TRACE, dan gunakan panduan OWASP (XSS Prevention Cheat Sheet) serta alat-alat pengujian (SAST/DAST, scanner, pentest) untuk menemukan dan menutup celah sebelum dipakai penyerang.

Contoh kerentanan:

- Cookie grabber

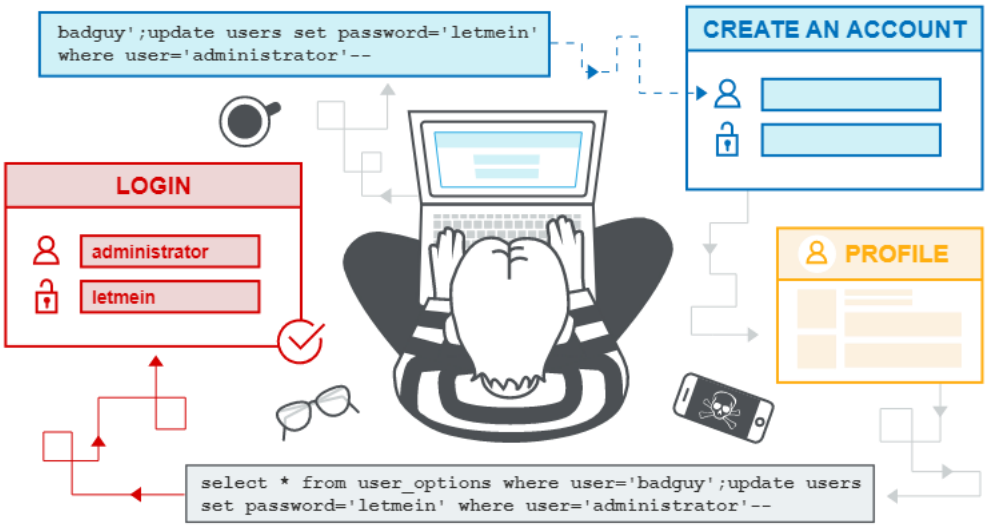
```
<SCRIPT type="text/javascript">
var adr = '../evil.php?cakemonster=' + escape(document.cookie);
</SCRIPT>
```

- Error page

```
<html>
<body>
<?php
print "Not found: " . urldecode($_SERVER["REQUEST_URI"]);?>

</body>
</html>
```

3. Apa yang dimaksud dengan serangan SQL Injection, dan bagaimana cara mencegahnya?



SQL Injection adalah teknik serangan di mana penyerang memasukkan atau menyisipkan perintah SQL berbahaya ke dalam input yang kemudian diproses langsung oleh database. Cara kerjanya sederhana namun berbahaya, penyerang memberi input yang membuat kueri berubah maksudnya sehingga database menjalankan perintah yang tidak diinginkan. Contohnya ketika aplikasi membuat kueri dengan mencantumkan teks dari pengguna tanpa perlindungan, maka input jahat bisa mengubah kondisi pencarian menjadi selalu benar atau bahkan mengeksekusi perintah hapus data.

Dampak dari SQL Injection bisa sangat serius karena menyerang bagian paling sensitif dari aplikasi yaitu penyimpanan data. Dengan celah ini penyerang bisa membaca data pribadi pengguna, mencuri password, menghapus atau merubah data, dan dalam kasus ekstrim bisa mendapatkan akses lebih jauh ke sistem backend. Kerugian tidak hanya teknis, organisasi juga bisa terkena dampak hukum dan reputasi yang panjang akibat kebocoran data.

Pencegahannya focus pada pemisahan data dari perintah. Artinya nilai yang masuk dari pengguna tidak boleh pernah disusun langsung menjadi string kueri yang dieksekusi oleh database. Sebagai gantinya gunakan mekanisme parameterisasi yang disediakan driver atau library database sehingga struktur kueri tetap sama dan nilai pengguna diperlakukan murni sebagai data. Selain itu perlu menerapkan prinsip hak paling minimum pada akun database yang digunakan aplikasi sehingga jika ada eksploitasi, kerusakan yang bisa dilakukan penyerang menjadi terbatas. Prinsip lain yang melengkapi adalah validasi input berbasis whitelist, hindari membangun kueri dinamis jika tidak perlu, dan lakukan logging serta monitoring untuk mendeteksi pola aneh.

Salah satu metodenya adalah:

- Penggunaan prepared statements atau parameterized queries

  Dengan psycopg2 untuk PostgreSQL gunakan placeholder %s

  ```
  import psycopg2
  conn = psycopg2.connect(dsn)
  cur = conn.cursor()
  email = request_params.get("email")
  cur.execute("SELECT id FROM users WHERE email = %s", (email,))
  user = cur.fetchone()
  ```

- Validasi input dan whitelist
- Stored procedures dan dynamic SQL
- Catat logging monitoring dan deteksi

4. Apa itu HTTPS, dan mengapa lebih aman daripada HTTP dalam menjaga keamanan website?

   HTTPS adalah singkatan dari Hypertext Transfer Protocol Secure, yaitu versi aman dari HTTP yang digunakan untuk pertukaran data antara browser dan server. Perbedaan utama HTTPS dengan HTTP ada pada penggunaan enkripsi melalui protokol SSL/TLS. Dengan enkripsi ini, semua data yang dikirimkan seperti username, password, detail kartu kredit, maupun informasi sensitif lainnya, diacak sehingga pihak ketiga yang mencoba mengintip lalu lintas jaringan tidak dapat membacanya dengan mudah.

   HTTP vs HTTPS

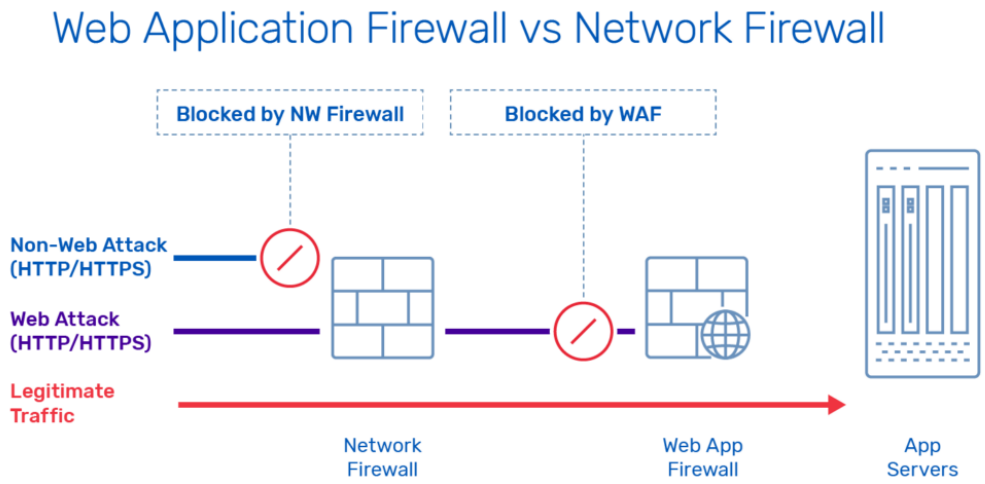
Fitur	HTTP	HTTPS
Security	Data is sent as plain text — easy to intercept.	Data is encrypted — safer from hackers.
Port	Uses port 80 by default.	Uses port 443 by default.
Trust	Browsers may label it "Not Secure."	Shows a padlock in the address bar.
Speed	Slightly slower on old systems.	Often faster due to newer protocols and optimizations.
Use case	Suitable for public or non-sensitive info.	Best for sensitive data like payments, logins, personal info.

   HTTPS lebih aman daripada HTTP karena mampu menjamin kerahasiaan, integritas, dan autentikasi. Kerahasiaan berarti hanya pengirim dan penerima sah yang bisa membaca isi data, bukan pihak lain yang menyadap di tengah jalur komunikasi. Integritas berarti data tidak bisa diubah oleh pihak ketiga saat sedang dikirim, karena setiap perubahan sekecil apa pun akan terdeteksi. Autentikasi diperoleh melalui sertifikat digital (SSL Certificate) yang diterbitkan oleh Certificate Authority (CA), sehingga pengguna bisa yakin bahwa website yang diakses benar-benar asli dan bukan tiruan buatan penyerang.

   Dalam praktik di dunia kerja, hampir semua organisasi dan bisnis wajib menggunakan HTTPS, bukan hanya untuk aplikasi yang melibatkan transaksi sensitif, tapi juga untuk website biasa. Alasan utamanya adalah kepercayaan pengguna dan standar keamanan industri yang makin ketat. Misalnya, Google Chrome menandai situs HTTP sebagai "Not Secure", dan mesin pencari memberi peringkat lebih baik untuk website dengan HTTPS. Implementasi terbaik di industri biasanya mencakup penggunaan TLS versi terbaru, konfigurasi cipher yang kuat, manajemen sertifikat yang baik, serta tambahan keamanan seperti HTTP Strict Transport Security (HSTS) untuk memaksa semua koneksi menggunakan HTTPS.

5. Jelaskan bagaimana firewall web berfungsi dalam melindungi server dari ancaman eksternal.

Firewall web atau lebih sering disebut Web Application Firewall (WAF) adalah sistem keamanan yang ditempatkan di depan server web untuk menyaring, memantau, dan memblokir lalu lintas berbahaya. Jika firewall jaringan biasa hanya melihat alamat IP, port, atau protokol, WAF bekerja lebih dalam sampai ke level HTTP/HTTPS request. Misalnya, WAF bisa mendeteksi pola serangan seperti SQL Injection, Cross-Site Scripting (XSS), brute force login, atau request aneh yang bisa membebani server. Dengan adanya WAF, hanya trafik yang dianggap aman yang diteruskan ke server, sehingga risiko serangan aplikasi web bisa ditekan.

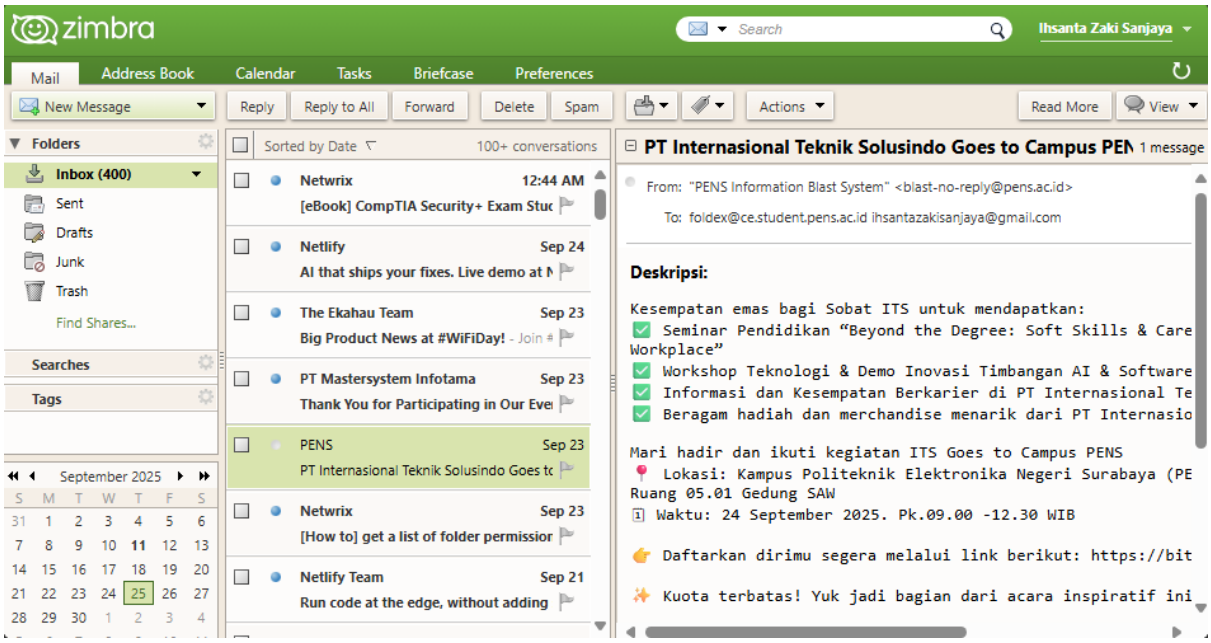


Apa perbedannya WAF dengan Firewall tradisional dan NGFW? Firewall (network firewall) pada dasarnya hanya berfokus pada lalu lintas jaringan. Ia bekerja di level IP dan port, misalnya mengizinkan trafik dari port 443 (HTTPS) dan menolak dari port 23 (Telnet). Firewall jenis ini tidak mengerti isi request web, jadi kalau ada serangan XSS atau SQL Injection yang dikirim lewat port 443, firewall tradisional tidak akan bisa mendeteksinya. Sebaliknya, WAF bekerja di level aplikasi sehingga bisa membaca isi HTTP header, URL, parameter, bahkan payload request. Jadi WAF lebih cocok untuk melindungi aplikasi web modern yang kompleks, sedangkan firewall tradisional lebih ke arah kontrol dasar lalu lintas jaringan.

NGFW atau Next-Generation Firewall adalah evolusi dari firewall tradisional yang menggabungkan berbagai fitur keamanan canggih. Selain fungsi dasar filtering IP dan port, NGFW biasanya punya kemampuan deep packet inspection, intrusion prevention system (IPS), kontrol aplikasi, sandboxing, serta integrasi dengan threat intelligence. Artinya NGFW bisa melihat lebih dalam ke lalu lintas jaringan, mengenali aplikasi tertentu (misalnya Zoom, WhatsApp, atau Facebook), bahkan mendeteksi malware atau exploit yang berusaha lewat protokol sah. Jika WAF fokus pada melindungi aplikasi web, NGFW lebih luas cakupannya: melindungi seluruh jaringan dari berbagai ancaman, baik di layer jaringan maupun sebagian di layer aplikasi.

Pertanyaan Tentang Webmail dan Kemanannya

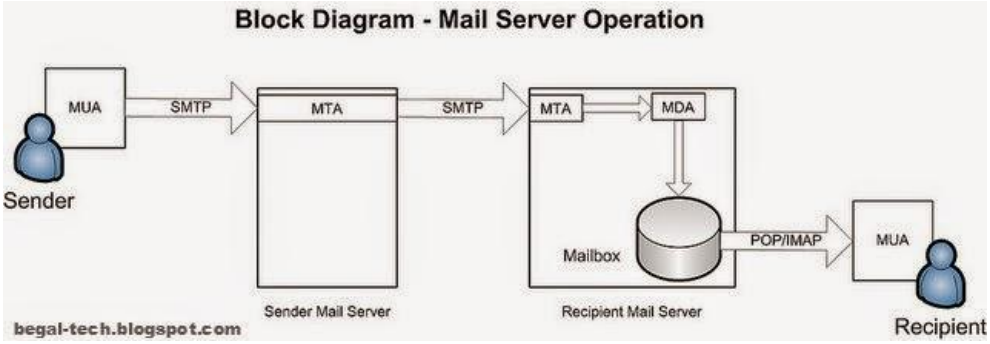
1. Apa itu webmail dan bagaimana cara kerjanya?



Contoh webmail pada kampus PENS dengan environment Zimbra (mail.student.pens.ac.id)

Webmail adalah layanan email berbasis web yang memungkinkan pengguna membaca, menulis, dan mengelola email melalui browser. Tidak seperti aplikasi email desktop yang harus dikonfigurasi terlebih dahulu, webmail hanya membutuhkan koneksi internet dan akun email aktif. Semua pesan disimpan di server email, sehingga pengguna dapat mengakses inbox, folder, maupun lampiran dari perangkat apa pun. Contoh layanan webmail yang populer adalah Gmail, Yahoo Mail, dan Outlook Web, sementara di dunia kerja sering digunakan webmail bawaan server seperti Roundcube atau Horde.

Cara kerjanya dimulai ketika pengguna membuka situs webmail melalui HTTP/HTTPS. Browser mengirim permintaan ke server aplikasi webmail, yang berfungsi sebagai antarmuka grafis untuk menampilkan email. Di balik layar, server webmail berkomunikasi dengan server email menggunakan protokol standar: SMTP untuk mengirim pesan keluar, serta IMAP atau POP3 untuk mengambil email masuk dari mailbox. Setelah data email berhasil diambil, server webmail mengolah dan mengubahnya menjadi halaman web yang bisa dipahami pengguna. Saat pengguna menulis email baru dan menekan tombol "Kirim," server webmail meneruskan pesan tersebut melalui SMTP ke server tujuan. Dengan alur ini, webmail menjembatani protokol email tradisional dengan tampilan berbasis web yang mudah diakses.



2. Mengapa keamanan webmail sangat penting bagi pengguna pribadi dan perusahaan?

   Keamanan webmail sangat penting bagi pengguna pribadi karena email sering digunakan sebagai pintu masuk utama ke berbagai layanan digital. Banyak akun media sosial, aplikasi, bahkan layanan perbankan terhubung dengan alamat email sebagai media verifikasi dan reset kata sandi. Jika email seseorang diretas, penyerang bisa mengambil alih akun-akun lain, mencuri informasi pribadi, hingga melakukan penipuan. Oleh karena itu, menjaga keamanan webmail berarti melindungi identitas digital dan mencegah kerugian pribadi yang lebih luas.

   Bagi perusahaan, keamanan webmail menjadi krusial karena email merupakan sarana komunikasi utama yang sering memuat data sensitif seperti dokumen internal, informasi keuangan, hingga strategi bisnis. Serangan seperti phishing, malware, atau email spoofing bisa menimbulkan kerugian besar, baik berupa pencurian data maupun kerusakan reputasi perusahaan. Dengan sistem webmail yang aman, perusahaan dapat memastikan kerahasiaan komunikasi, mencegah kebocoran data, serta menjaga kepercayaan mitra dan pelanggan. Karena itu, penerapan keamanan webmail bukan sekadar tambahan, melainkan bagian inti dari strategi keamanan siber organisasi.

   Bagi universitas, keamanan webmail sangat penting karena email digunakan sebagai sarana resmi komunikasi antara dosen, mahasiswa, dan staf. Akun webmail biasanya terhubung dengan layanan penting lain, seperti sistem informasi akademik, portal e-learning, hingga akses perpustakaan digital. Jika keamanan webmail terabaikan, data pribadi mahasiswa maupun data akademik bisa dicuri, disalahgunakan, atau bahkan dimanipulasi oleh pihak yang tidak bertanggung jawab. Hal ini tentu dapat merugikan mahasiswa secara individu sekaligus merusak kepercayaan terhadap institusi. Universitas sering menjadi target serangan karena memiliki banyak data sensitif, seperti hasil penelitian, kerja sama dengan industri, hingga informasi pendanaan. Penyerang bisa memanfaatkan email untuk menyebarkan phishing atau malware kepada civitas akademika, yang berpotensi melumpuhkan sistem internal. Dengan menjaga keamanan webmail, universitas tidak hanya melindungi data mahasiswanya, tetapi juga menjaga reputasi akademik serta memastikan kelancaran kegiatan pendidikan dan penelitian.

3. Sebutkan beberapa ancaman keamanan umum yang sering menyerang layanan webmail.

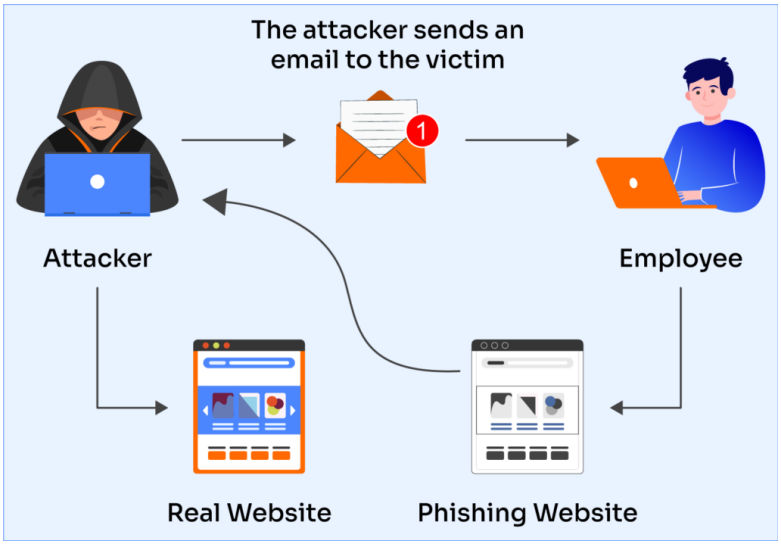
   Terdapat banyak ancaman, salah satunya adalah:
   - Phising, serangan ini menggunakan email palsu yang seolah-olah berasal dari pihak resmi, seperti bank, universitas, atau layanan populer. Tujuannya untuk menipu pengguna agar memberikan informasi sensitif, misalnya username, password, atau data kartu kredit.
   - Malware melalui lampiran atau tautan, penyerang sering menyisipkan file berbahaya atau tautan ke situs berisi malware dalam email. Begitu dibuka,

malware bisa mencuri data, mengendalikan perangkat, atau menyebar ke jaringan organisasi.

- Spam, email tidak diinginkan dalam jumlah besar yang dapat memenuhi inbox. Selain mengganggu, spam juga sering menjadi media penyebaran phishing atau malware.
- Email Spoofing, penyerang memalsukan alamat pengirim agar terlihat seolah berasal dari sumber terpercaya. Teknik ini biasanya dipakai untuk memicu kepercayaan korban agar membuka lampiran atau tautan berbahaya.
- Man-in-the-Middle Attack (MitM), jika koneksi ke webmail tidak diamankan dengan HTTPS, penyerang bisa menyadap komunikasi antara pengguna dan server. Akibatnya, username, password, atau isi email bisa dicuri.
- Brute Force dan Credential Stuffing, penyerang mencoba menebak password dengan kombinasi acak (brute force) atau menggunakan database password bocor dari layanan lain (credential stuffing) untuk masuk ke akun email korban.
- Account Takeover (ATO), setelah berhasil menguasai akun webmail, penyerang bisa menggunakannya untuk mengakses layanan lain yang terhubung dengan email tersebut, mengirim phishing lebih lanjut, atau mencuri data sensitif.
- Business Email Compromise (BEC), ancaman ini lebih sering menyerang organisasi atau universitas. Penyerang menyamar sebagai pimpinan atau staf resmi melalui email palsu untuk menipu korban agar mentransfer dana atau membocorkan informasi penting.
- Denial of Service (DoS) pada server webmail, penyerang bisa membanjiri server webmail dengan trafik atau email dalam jumlah besar sehingga server tidak bisa diakses oleh pengguna sah.

4. Apa itu phishing dan bagaimana phishing dapat menyerang pengguna webmail?

   Apa itu phishing? Phishing adalah bentuk penipuan siber di mana penyerang menyamar sebagai pihak terpercaya, seperti bank, universitas, perusahaan, atau bahkan layanan webmail resmi, untuk mengelabui korban agar memberikan informasi sensitif. Informasi yang ditargetkan biasanya berupa username, password, nomor kartu kredit, atau data pribadi lainnya. Serangan phishing umumnya dikirim melalui email yang tampak asli, dengan logo, alamat, atau gaya bahasa yang meniru lembaga resmi, sehingga banyak pengguna tertipu dan percaya bahwa email tersebut sah.



Dalam konteks webmail, phishing dapat menyerang dengan cara mengirimkan email berisi tautan palsu menuju situs yang menyerupai halaman login resmi webmail. Saat pengguna memasukkan kredensialnya di situs palsu tersebut, data langsung dicuri oleh penyerang. Selain itu, phishing juga bisa datang dalam bentuk lampiran berbahaya yang, jika dibuka, dapat memasang malware pada perangkat korban. Dampaknya sangat berbahaya: akun webmail bisa diambil alih, data sensitif bocor, hingga digunakan untuk menyebarkan serangan phishing baru kepada kontak korban.

5. Jelaskan bagaimana Two-Factor Authentication (2FA) dapat meningkatkan keamanan webmail.

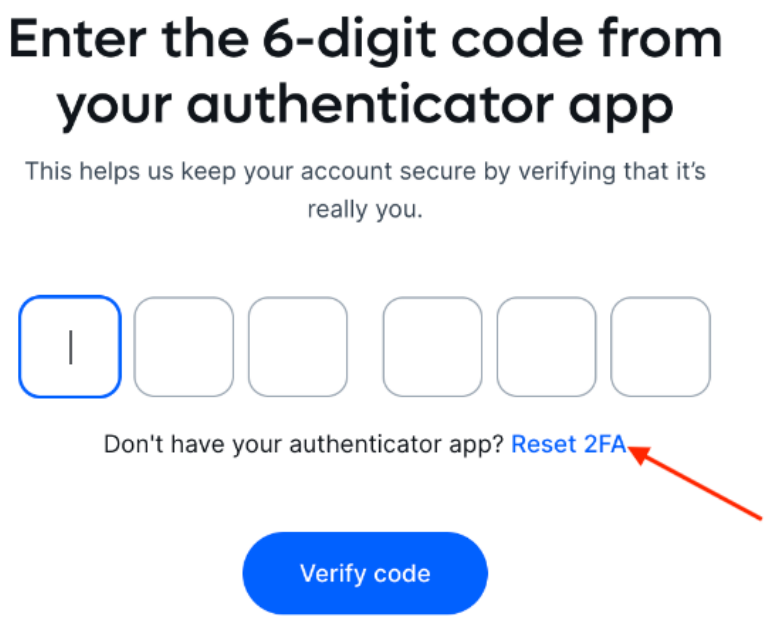
   Two-Factor Authentication (2FA) adalah mekanisme keamanan tambahan yang mewajibkan pengguna memberikan dua bukti identitas saat login, biasanya berupa kombinasi password dan kode verifikasi tambahan. Pada layanan webmail, setelah memasukkan password, pengguna akan diminta memasukkan kode OTP (One-Time Password) yang dikirim melalui SMS, aplikasi autentikator, atau perangkat fisik seperti token keamanan. Dengan cara ini, meskipun password pengguna berhasil dicuri melalui phishing atau serangan brute force, penyerang tetap tidak bisa masuk tanpa faktor kedua tersebut.

   Keunggulan 2FA sangat terasa baik bagi individu maupun organisasi. Untuk individu, 2FA mencegah penyerang mengambil alih akun meski password sudah bocor atau ditebak. Sementara bagi organisasi, penerapan 2FA bisa mengurangi risiko penyalahgunaan akun karyawan, melindungi database sensitif, hingga menjaga reputasi dari serangan siber seperti phishing atau credential stuffing. Implementasi 2FA kini juga semakin mudah karena banyak layanan memanfaatkan perangkat seluler pengguna, baik dengan OTP melalui SMS, panggilan suara, maupun notifikasi push yang hanya perlu satu ketukan untuk menyetujui login. Hal ini menjadikan 2FA tidak sekadar aman, tetapi juga praktis untuk digunakan sehari-hari.

   Terdapat beberapa metode autentikasi yang digunakan dalam autentikasi dua faktor. Berikut ini daftar opsi yang paling popular:

   1. **Token perangkat keras**, Pelaku bisnis dapat memberikan token perangkat keras kepada karyawan dalam bentuk gantungan kunci yang akan menghasilkan kode setiap beberapa detik hingga satu menit. Ini adalah salah satu bentuk autentikasi dua faktor tertua.
   2. **Pemberitahuan push**, Metode otentikasi dua faktor push tidak memerlukan kata sandi. Jenis 2FA ini mengirimkan sinyal ke telepon Anda untuk menyetujui/menolak atau menerima/menolak akses ke situs web atau aplikasi guna memverifikasi identitas Anda.

3. **Verifikasi SMS**, SMS atau pesan teks, merupakan salah satu bentuk autentikasi dua faktor, yaitu ketika pesan dikirim ke nomor telepon tepercaya. Pengguna diminta berinteraksi dengan teks atau menggunakan kode sekali pakai untuk memverifikasi identitas mereka di situs atau aplikasi.
4. **Autentikasi berbasis suara**, Autentikasi suara bekerja layaknya pemberitahuan push, bedanya identitas Anda dikonfirmasi melalui automasi. Suara tersebut akan meminta Anda menekan tombol atau menyebutkan nama Anda untuk mengidentifikasi diri Anda.



Contoh penerapan 2FA dengan kode tambahan dari aplikasi autentikasi

Penerapan 2FA pada webmail sangat efektif dalam mencegah pengambilalihan akun, karena password saja tidak lagi cukup untuk mendapatkan akses. Faktor kedua biasanya bersifat dinamis dan hanya berlaku untuk waktu singkat, sehingga sulit dipalsukan. Bagi organisasi atau universitas, penggunaan 2FA juga meningkatkan kepercayaan bahwa komunikasi melalui webmail lebih aman, melindungi data sensitif, serta mengurangi risiko penyalahgunaan akun oleh pihak yang tidak berwenang. Dengan demikian, 2FA menjadi salah satu praktik terbaik untuk menjaga keamanan webmail di era serangan siber yang semakin canggih.

Sebagai bonus saya akan mempraktikkan pembuatan webmail sederhana di Ubuntu. Dengan focus pada instalasi dasar sampai dapat logi webmail via browser.

Software yang digunakan: Postfix, Dovecot, Roundcube
Environtment: Ubuntu 24-04 LTS

1. Update paket terlebih dahulu

```
sudo apt update && sudo apt upgrade -y
```

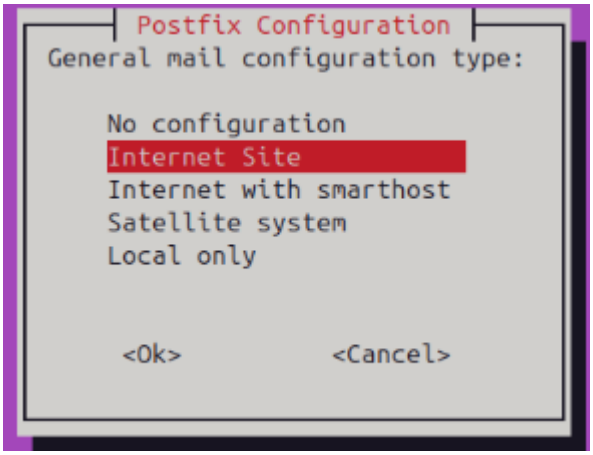
```
foldexz@foldexz:~$ sudo apt update && sudo apt upgrade -y
[sudo] password for foldexz:
Hit:1 http://archive.ubuntu.com/ubuntu noble InRelease
Get:2 http://archive.ubuntu.com/ubuntu noble-updates InRelease [126 kB]
Get:3 http://security.ubuntu.com/ubuntu noble-security InRelease [126 kB]
Get:4 http://archive.ubuntu.com/ubuntu noble-backports InRelease [126 kB]
Get:5 http://security.ubuntu.com/ubuntu noble-security/main amd64 Packages [1,16
```

2. Install Postfix & Dovecot

```
sudo apt install postfix dovecot-core dovecot-imapd -y
```

```
foldexz@foldexz:~$ sudo apt install postfix dovecot-core dovecot-imapd -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
```

Pilih internet site



Isi domain, misalnya foldexz.local

3. Install database MariaDB untuk Roundcube

```
sudo apt install mariadb-server -y
```

```
foldexz@foldexz:~$ sudo apt install mariadb-server -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
```

4. Install Roundcube webmail

```
sudo apt install roundcube roundcube-mysql roundcube-plugins -y
```

```
foldexz@foldexz:~$ sudo apt install roundcube roundcube-mysql roundcube-plugins
-y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
```

Klik Yes

```
Configuring roundcube-core

The roundcube package must have a database installed and configured
before it can be used. This can be optionally handled with
dbconfig-common.

If you are an advanced database administrator and know that you want to
perform this configuration manually, or if your database has already
been installed and configured, you should refuse this option. Details on
what needs to be done should most likely be provided in
/usr/share/doc/roundcube.

Otherwise, you should probably choose this option.

Configure database for roundcube with dbconfig-common?

                <Yes>                    <No>
```

Isikan password dengan kerumitan atau pola tertentu.

5. Konfigurasi Apache agar dapat mengakses Roundcube

```
sudo nano /etc/apache2/conf-enabled/roundcube.conf
```

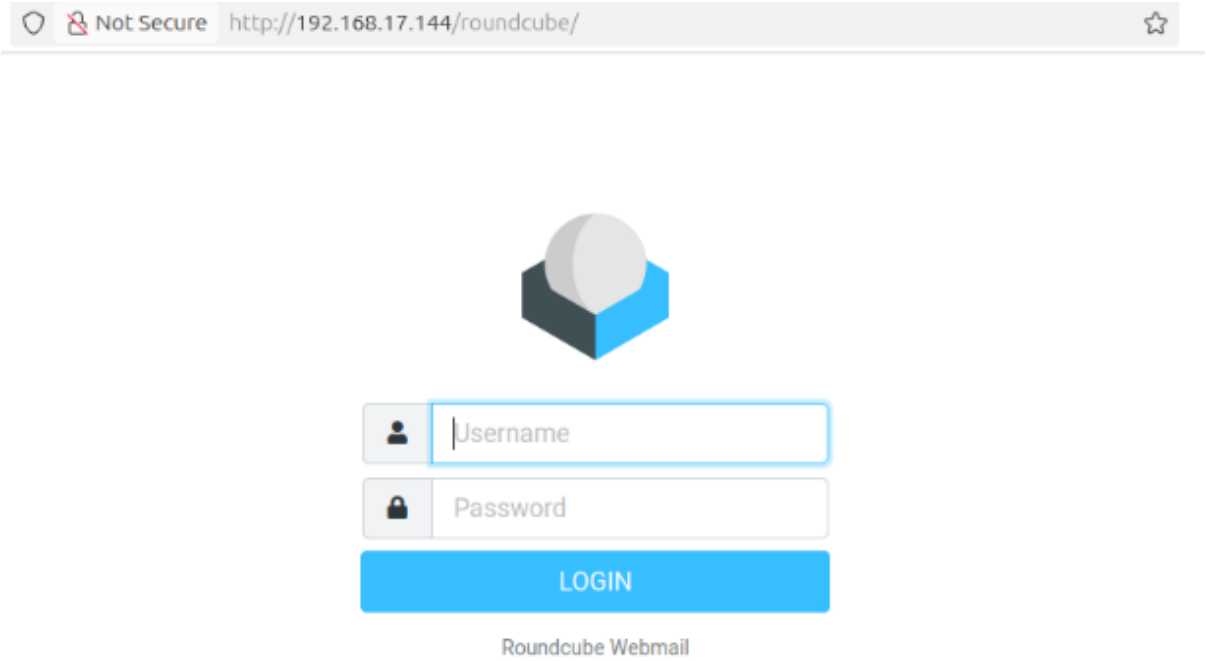
Pastikan terdapat “Alias /roundcube /var/lib/roundcube”

```
  GNU nano 7.2          /etc/apache2/conf-enabled/roundcube.conf *
# Those aliases do not work properly with several hosts on your apache server
# Uncomment them to use it or adapt them to your configuration
    Alias /roundcube /var/lib/roundcube/public_html
```

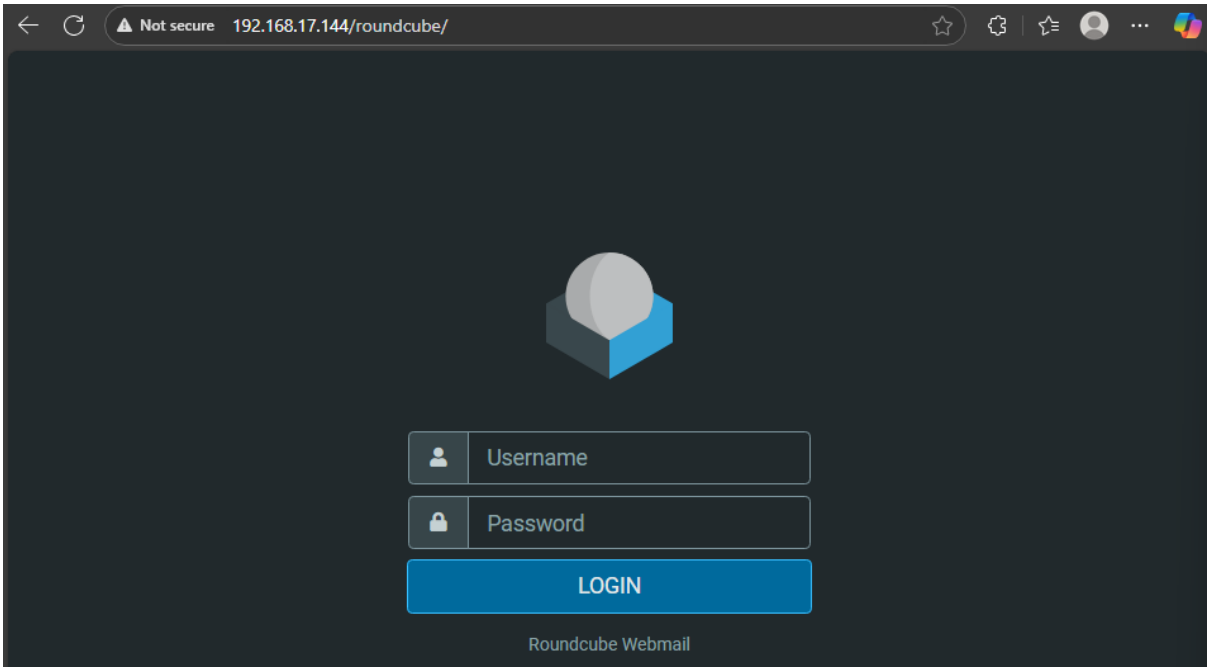
Restart service

```
sudo systemctl restart apache2
```

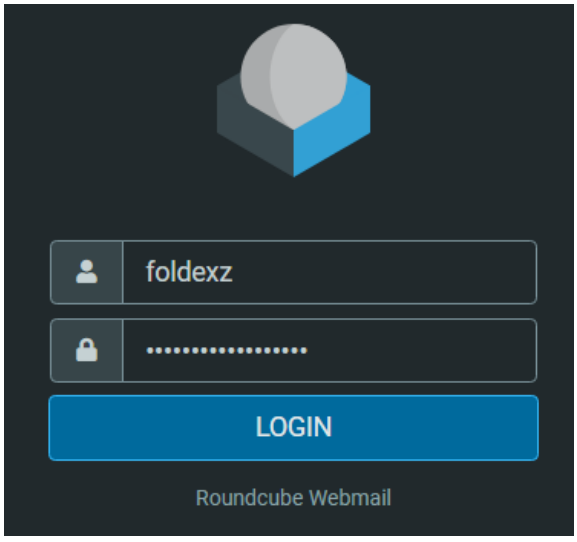
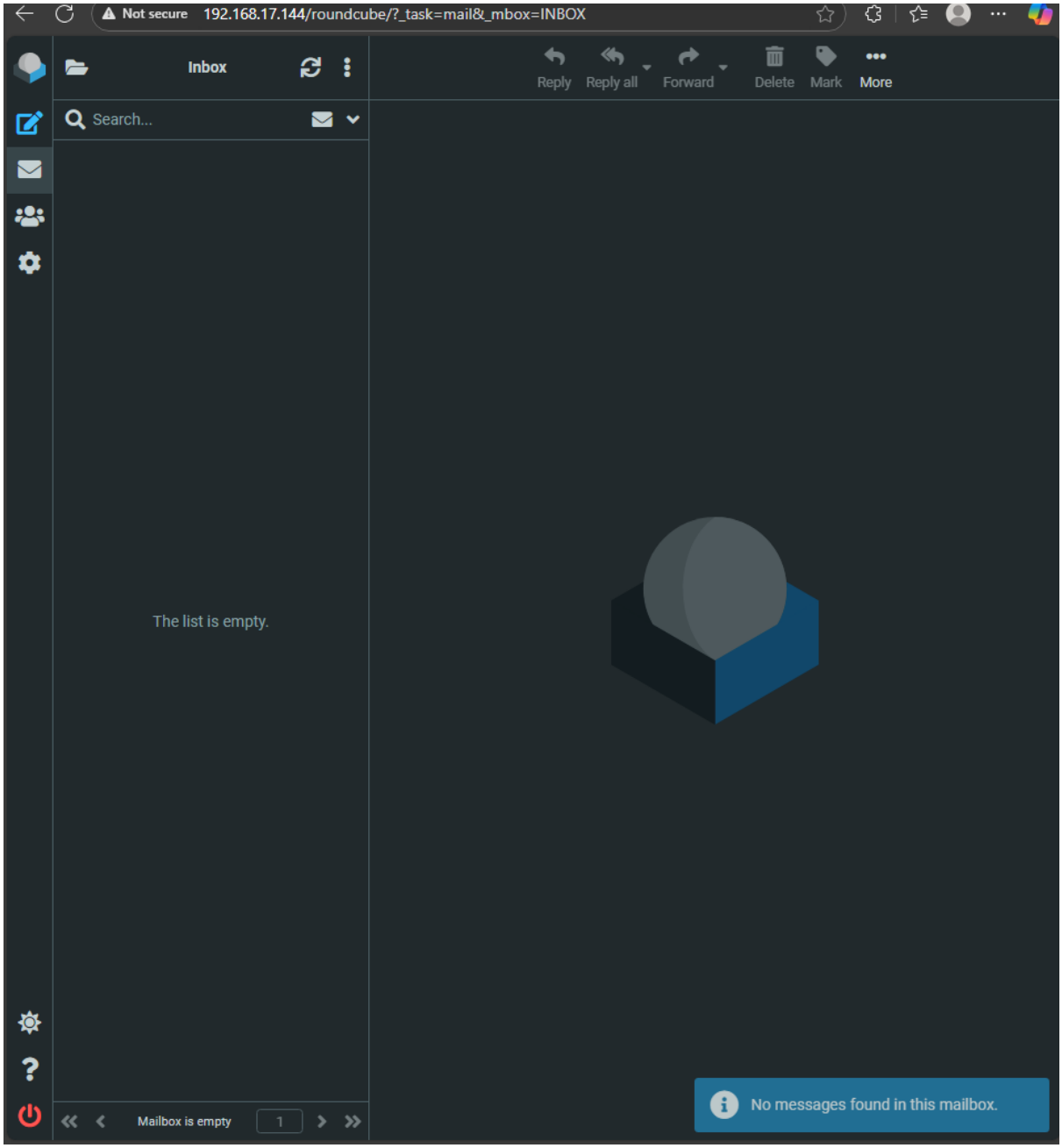
6. Akses Webmail via Browser dengan interface yang ada pada Ubuntu
http://IPADDRESS/roundcube/



Bahkan dari PC dengan OS windows juga bisa karena dalam 1 jaringan yang sama



Login dengan username pada Ubuntu



Berikut merupakan tampilan awal dari web mail roundcube